Kriptográfia és biztonság 7.

Hash

Hash függvények adat-struktúrákban

- a hash függvény egy kompressziós függvény
- tetszőleges input-hossz
- $H : \{0,1\}^* \mapsto \{0,1\}^n$, ahol $n = 128, 160, 256, etc$
- klasszikus alkalmazás: adat-struktúrák
  - elemek tárolása egy k méretű táblában
  - beszúrás és keresés konstans időben
  - az x elemet a $H(x)$ cellában tároljuk
  - x visszanyerhető $H(x)$ kiszámításával és a megfelelő cella-értékkel
- *ütközés*: $x \neq x' : H(x) = H(x')$
- „jó” hash függvény, ha kevés ütközés van
- megfelelően szétszórja az elemeket

Kriptográfiai hash függvények

- adat tömörítés
- kevés ütközés
- az ütközésmentesség
  - adat-struktúrákban csak elvárt
  - kriptóban elengedhetetlen
- adat-struktúrákban x és $H(.)$ független
- kriptóban a támadó tetszőlegesen választhatja x-et
- kripto hash-et sokkal nehezebb konstruálni...

Kriptográfiai hash függvények

Definíció

*Egy **ütközés** a $H(.)$ függvényben egy $x \neq x'$ input-pár, amire $H(x) = H(x')$.*
*A $H(.)$ függvény **ütközés-mentes**, ha bármely PPT támadó csak elhanyagolható valószínűséggel talál ütközést.*
A $H(.)$ függvény egy hash függvény, ha $H : \{0,1\}^* \mapsto \{0,1\}^n$.

Kriptográfiai hash függvények

Definíció

*Egy **ütközés** a $H(.)$ függvényben egy $x \neq x'$ input-pár, amire $H(x) = H(x')$.*
*A $H(.)$ függvény **ütközés-mentes**, ha bármely PPT támadó csak elhanyagolható valószínűséggel talál ütközést.*
A $H(.)$ függvény egy hash függvény, ha $H : \{0,1\}^* \mapsto \{0,1\}^n$.

Gyengébb biztonsági definíciók

1. Ütközés-mentesség: lásd fent
2. **Második őskép biztonság**: adott x-hez PPT támadó nem képes találni $x' \neq x : H(x') = H(x)$
3. **Őskép biztonság**: adott $y = H(x)$-hez, random (és ismeretlen) x esetén PPT támadó nem képes találni $x' : H(x') = y$ (magyarul egyirányú függvény)

Kriptográfiai hash függvények

Tervezési alapelvek

- Hatékonyság: adott m-re $H(m)$ gyorsan számítható
- Ütközés-mentesség
- (Második) őskép biztonság

Kriptográfiai hash függvények

Tervezési alapelvek

- Hatékonyság: adott m-re $H(m)$ gyorsan számítható
- Ütközés-mentesség
- (Második) őskép biztonság
- **Lavina hatás**: kis változás az inputban $\Rightarrow$ nagy változás az outputban
  - **Szigorú lavina kritérium:** ha egy input bitet megváltoztaunk $\Rightarrow$ minden output bit 1/2 valószínűséggel megváltozik
  - **Bit függetlenség kritérium:** $\forall i, j, k$: ha az i-ik input bit megváltozik $\Rightarrow$ a j, k output bitek megváltozása egymástól független

Kriptográfiai hash függvények

Tervezési alapelvek

- Hatékonyság: adott m-re $H(m)$ gyorsan számítható
- Ütközés-mentesség
- (Második) őskép biztonság
- **Lavina hatás**: kis változás az inputban $\Rightarrow$ nagy változás az outputban
  - **Szigorú lavina kritérium:** ha egy input bitet megváltoztaunk $\Rightarrow$ minden output bit 1/2 valószínűséggel megváltozik
  - **Bit függetlenség kritérium:** $\forall i, j, k$: ha az i-ik input bit megváltozik $\Rightarrow$ a j, k output bitek megváltozása egymástól független
- **Véletlen orákulum:** black-box, ami $\forall$ kérdésre az output-tér egy uniform véletlen elemét adja vissza

Támadások

Születésnap támadás (Birthday attack)

Egy $H : \{0,1\}^* \mapsto \{0,1\}^n$ hash-függvényre ütközés található 1/2 valószínűséggel, ha $2^{n/2}$ hash értéket kiszámítunk.

- Lényegesen gyorsabb, mint a brute-force
- Ha gyorsabban találunk ütközést, mint a születésnap támadás $\Longrightarrow$ a hash-t "feltörtük"

Merkle-Damgård transzformáció

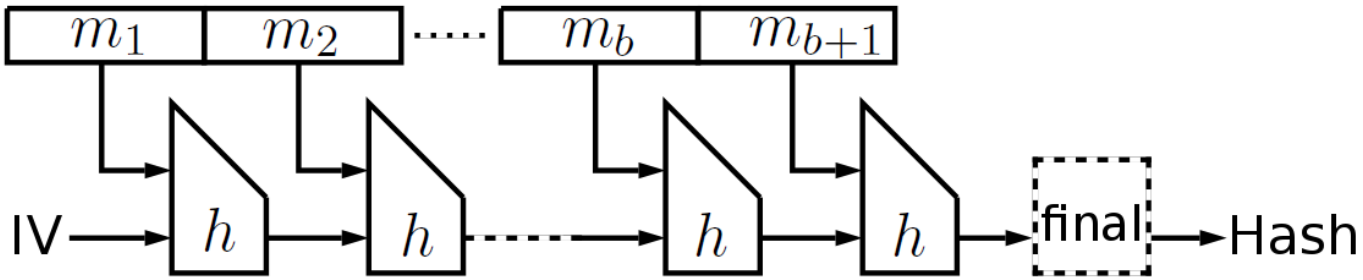
Alapötlet

- gyakorlati konstrukciók csak fix hosszú bemenetet kezelnek
- módszer tetszőleges inputú hash függvényekre
- legyen $h : \{0,1\}^{2n} \mapsto \{0,1\}^n$ fix bemenetú hash fv, $m \in \{0,1\}^*$, ahol $|m| = \ell < 2^n$
- láncolási szabályokhoz hasonló iteratív konstrukció
- $\Rightarrow H(.)$ egy tetszőleges inputú hash függvény

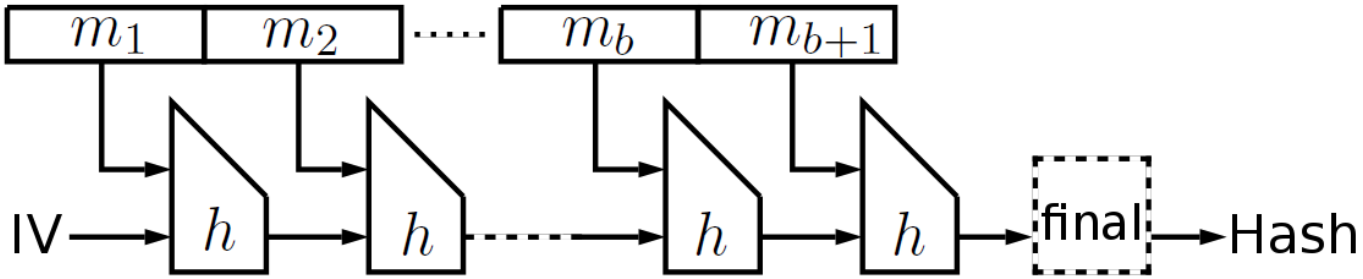
Merkle-Damgård transzformáció

Merkle-Damgård transzformáció

1. daraboljuk m-et n hosszú blokkokra: $b := \lceil \frac{\ell}{n} \rceil$ és $m = (m_1|m_2|\ldots|m_b)$
2. legyen $m_{b+1} := \ell \in \{0,1\}^k, z_0 := IV$
3. $i = 1, \ldots, b+1$ esetén számítsuk ki $z_i := h(z_{i-1}|m_i)$
4. $H(m) := z_{b+1}$



Merkle-Damgård transzformáció



Tulajdonságok

- gyakorlatban: elég fix hosszúságot kezelő konstrukció
- elméletben: az összenyomás mennyisége mindegy
- inicializáló vektor – $IV : z_0$ szabadon választható
- biztonság:ha $h(.)$ ütközésmentes, akkor $H(.)$ is az

Támadások

Alapok

- Ütközés-keresés lvl2: születésnap támadás + kriptanalízis
- Multi-ütközés: $m_1, \ldots, m_k : H(m_1) = \cdots = H(m_k)$

Támadások

Alapok

- Ütközés-keresés lvl2: születésnap támadás + kriptanalízis
- Multi-ütközés: $m_1, \ldots, m_k : H(m_1) = \cdots = H(m_k)$

Választott-prefix támadás

adott $p_1 \neq p_2$ prefixre keresni $m_1, m_2 : H(p_1, m_1) = H(p_2, m_2)$.

Herding attack

multi-ütközés + választott prefix

- Merkle-Damgård sérülékenység
- Gyakorlati támadások MD5-alapú implementációk ellen

Támadások

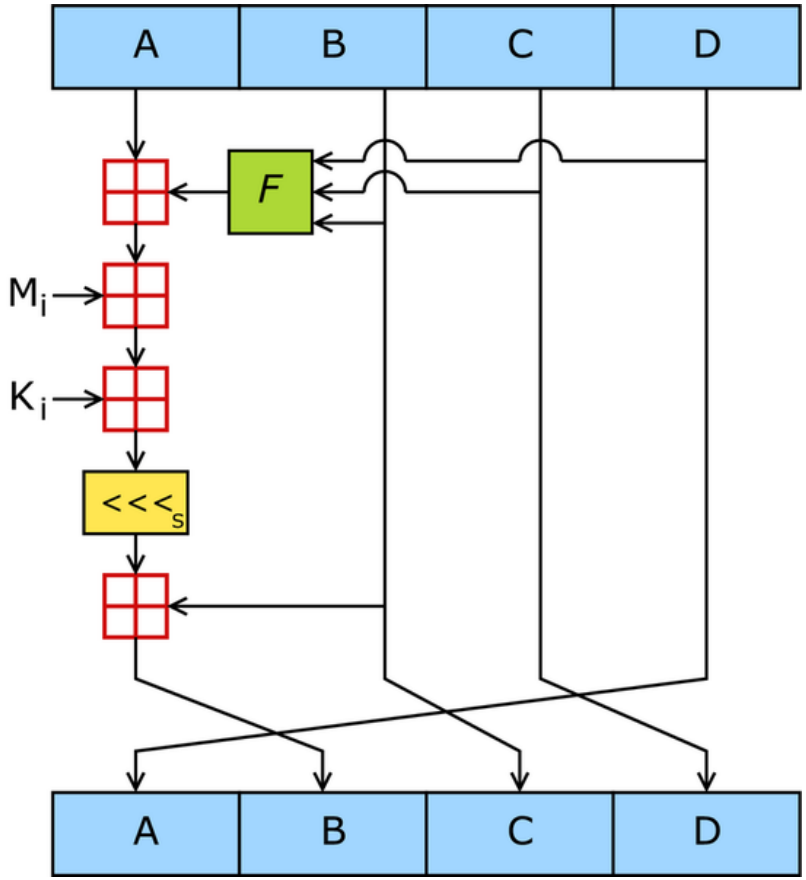
Lenght-extension attack

Adott $H(m)$ hash érték és $|m|$ üzenethossz-ra kiszámít $H(m||m')$ valamely m'-re (m nem ismert!).

- Padding-alapú támadás
- $H(data, padding) \Rightarrow$
  $H(data, padding, OurData, NewPadding)$
- Merkle-Damgård sérülékenység
- Gyakorlati ámadások MD5, SHA1, SHA2 ellen (flickr 2009)

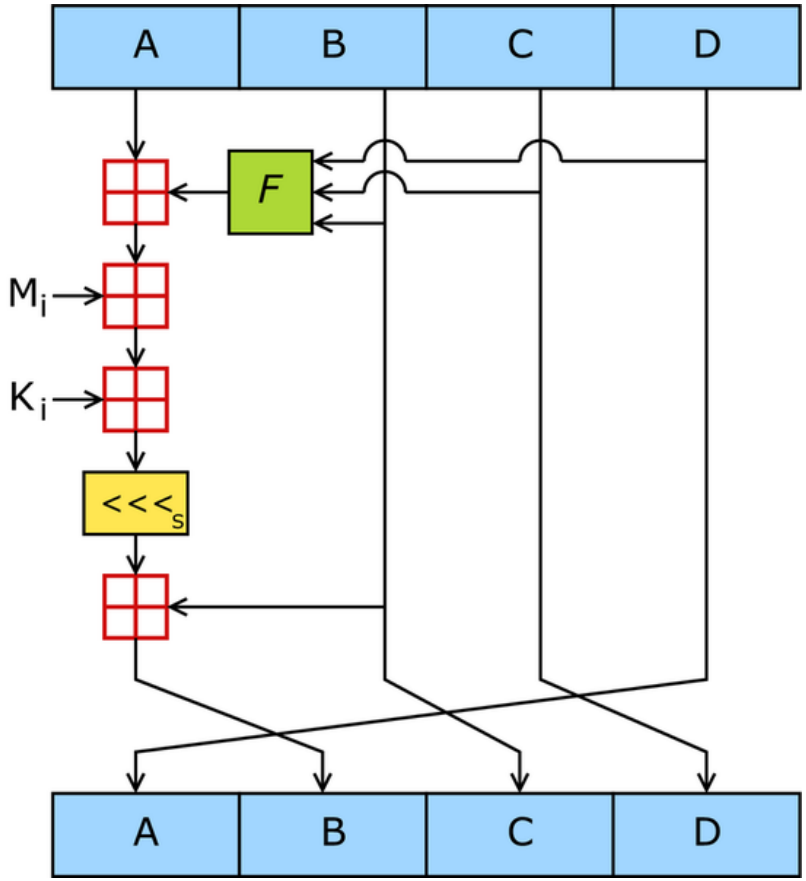
MD5 - leírás

- 512-ről 128 bitre összenyomás kiterjesztve Merkle-Damgård-dal
- 32-bites szavakon működik
- m felosztása 512(=16*32)-bit blokkokra
- 128(=4*32)-bit állapotokon operál
- A, B, C, D rögzített
- 4 kör, mindben 16 hasonló művelet
- négy nem-lineáris F:
  1. $F(B,C,D) = (B \wedge C) \vee (\neg B \wedge D)$
  2. $G(B,C,D) = (B \wedge D) \vee (C \wedge \neg D)$
  3. $H(B,C,D) = B \oplus C \oplus D$
  4. $I(B,C,D) = C \oplus (B \vee \neg D)$
- M_i az üzenet blokk
- K_i konstans, s eltolási paraméter (műveletenként változik)



MD5 – elemzés

- NEM ütközésmentes!
- 128 bit output $\Longrightarrow$ születésnap támadás...
- 1992 - MD5 publikálása
- 1993 - „pszeudo-ütközés” a kompressziós függvényben (IV alapú támadás)
- 1996 - ütközés a kompressziós függvényben
- 2004 - MD5CRK, születésnap alapú elosztott támadás
- 2004 - hash ütközés 1 órán belül (analitikus támadás)
- 2005 - gyakorlati ütközés két X.509 tanúsítványban, aminek különböző a kulcsa, de uaz az MD5 hash-e
- 2010 - első publikált egy blokkos ütközés



SHA hash család

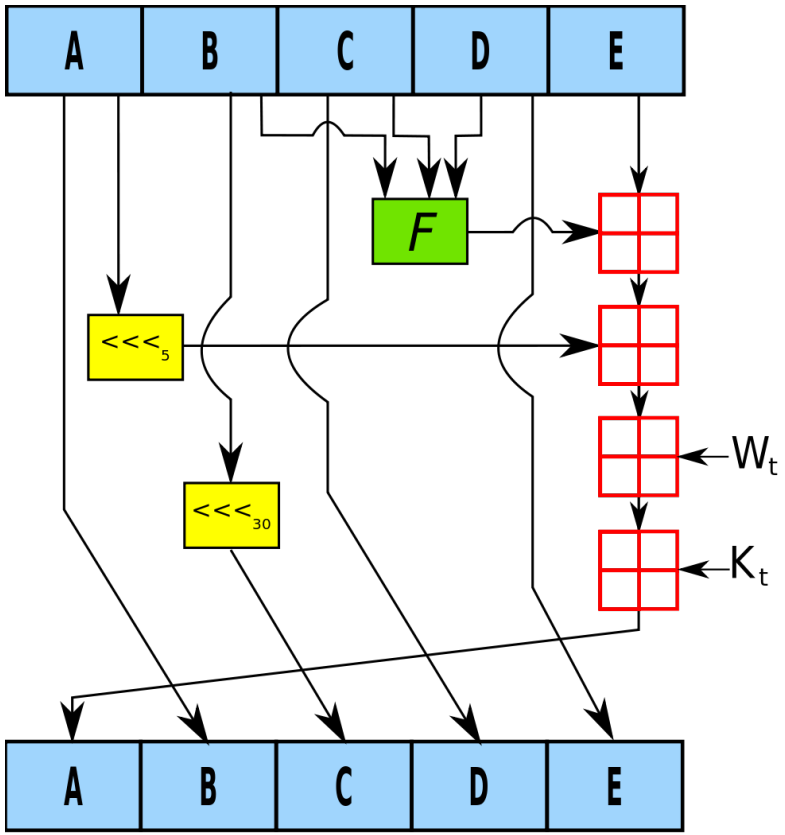
- SHA – Secure Hash Algorithm
- U.S. NSA fejlesztés, U.S. NIST publikálta

SHA-0 (1993)

- 160-bit output, 32-bites szavak, 80 kör
- műveletek: $\oplus, \boxplus, \wedge, \vee, \lll$
- ütközés...

SHA-1 (1995)

- 160-bit output, 32-bites szavak, 80 kör
- ellenállóbb, elméleti támadás 2^{61} lépésben (2011)



SHA-1, original diagram for Wikipedia created by User:Matt Crypto

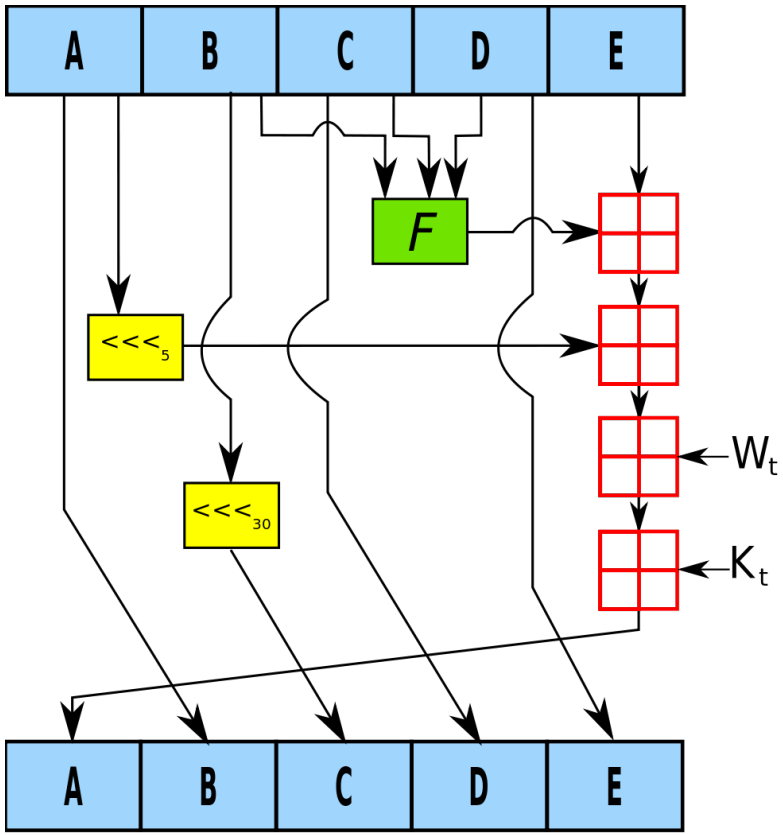
SHA hash család

SHA-2 (2001) = SHA-256/SHA-512

- 256/512-bit output, 32/64-bites szavak, 64/80 kör
- nincs (ismert) ütközés

SHA-3 (2014-)

- eltérő design
- az SHA-2 alternatívája



SHA-1, original diagram for Wikipedia created by User:Matt Crypto

NIST hash függvény verseny (2007 – 2012)

Az AES versenyhez hasonló fejlesztési folyamat

Oct. 2008 beküldési határidő

Dec. 2008 Round 1: 51 megmaradt jelölt

Feb. 2009 NIST konferencia: beküldött algoritmusok ismertetése

Jul. 2009 Round 2: 14 elfogadott jelölt

Aug. 2010 CRYPTO 2010: a második körös jelöltek elemzése

Dec. 2010 Döntősök kihirdetése

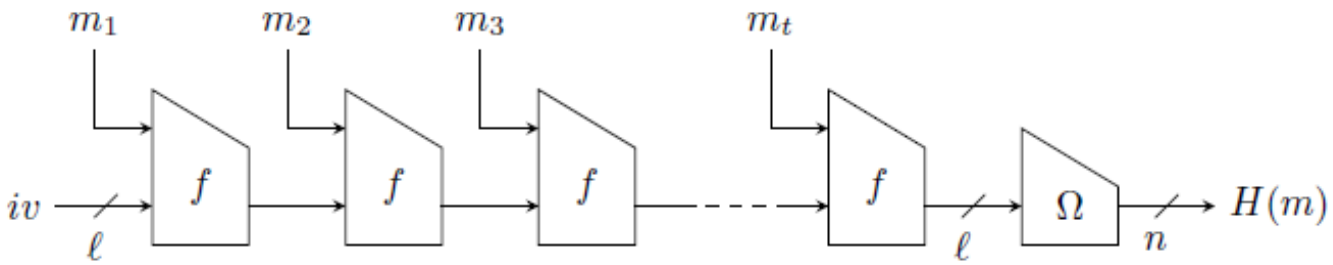
- teljesítmény: alacsony hardver követelmények
- biztonság: lehetséges kripto/tervezési gyengeségek
- elemzés: kriptanalízis (hiánya) a teljes kripto-közösséggel
- diverzitás: különböző működési módok és belső állapotok

Dec. 2012 Győztes: Keccak

Aug. 2013 NIST változásokat jelent be a javasolt standardhoz képest, a "jobb biztonság/teljesítmény arány érdekében"...

Aug. 2015 Keccak az új SHA-3 hash standard

Egy döntős: Grøstl

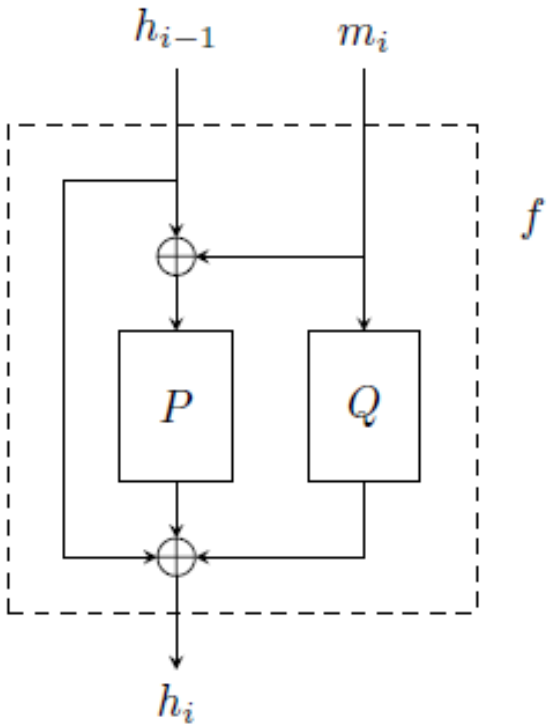


A Grøstl hash-function

- Knudsen et al. (TU of Denmark & TU Graz)
- Módosított Merkle-Damgård
  - $h_0 = iv, h_i = f(h_{i-1}, m_i)$
  - f kompressziós fv P, Q permutációkból (ld. köv fólia)
  - $H(m) = \Omega(h_t)$
  - Output transformáció $\Omega(x) = \mathrm{trunc}_n(P(x) \oplus x)$

Egy döntős: Grøstl

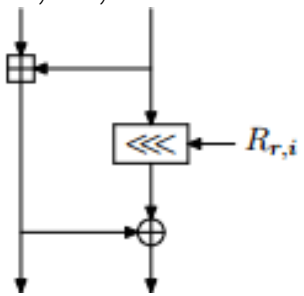
- $f(h, m) = P(h \oplus m) \oplus Q(m) \oplus h$
- P és Q tervezése az AES alapján
- Kevés permutáció $\Longrightarrow$ egyszerű elemzés
- Jól ismert tervezési elvek
- Biztonságos, ha P, Q ideális
- Ütközés $\geq 2^{\ell/4}$ P, Q kiértékelésből
- Őskép $\geq 2^{\ell/2}$ P, Q kiértékelésből
- Megkülönböztethetlen a random orákulumtól

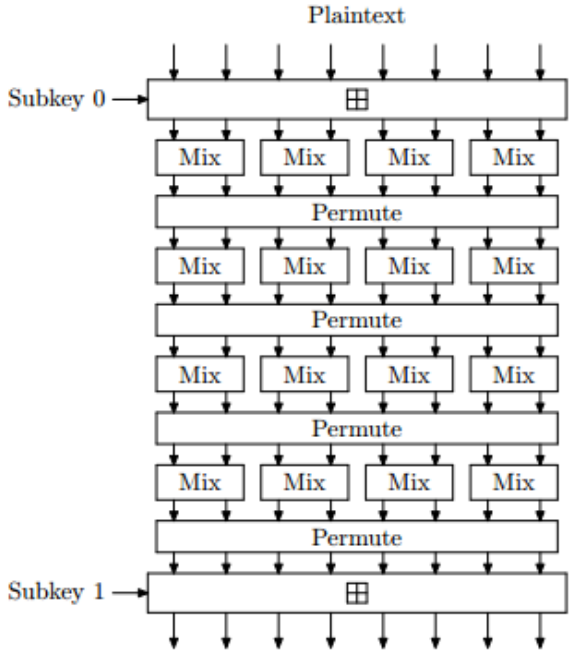


A Grøstl kompressziós fv-e

Egy döntős: Skein

- Schneier és társai
- Fő komponensek
  1. Threefish
     - tweak-elhető blokk-titkosító
     - Tweak: extra input, ami variálhatóságot biztosít
     - Sok egyszerű kör a kevés bonyolult helyett
     - Kulcs + tweak $\rightsquigarrow$ részkulcsok
     - Mix: $\oplus$, $\boxplus$, $<<<$

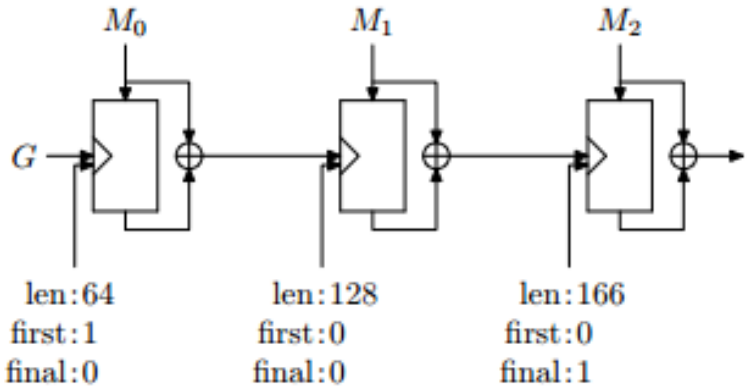




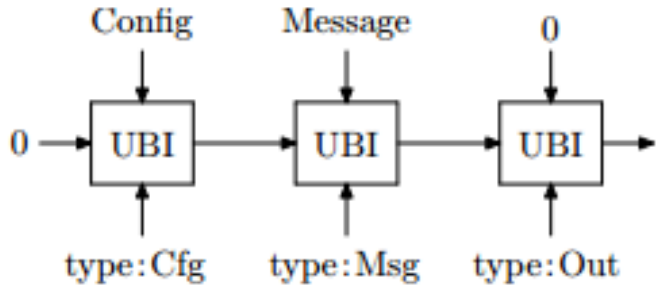
A Threefish-512 4 köre a 72-ből

Egy döntős: Skein

- Fő komponensek
  2. Unique Block Iteration (UBI):
     - Threefish működési mód, cél: kompressziós fv
     - Pl: 3 db Threefish-512 hívás
     - Tweak: hossz, első/utsó blokk, „type”
     - Skein: UBI többszöri hívása
  3. Optional Argument System
     - Kiterjesztések és egyéb módok



3-blokkos üzenet hash-elése UBI-val



Skein normál hash módban

SHA-3/Keccak

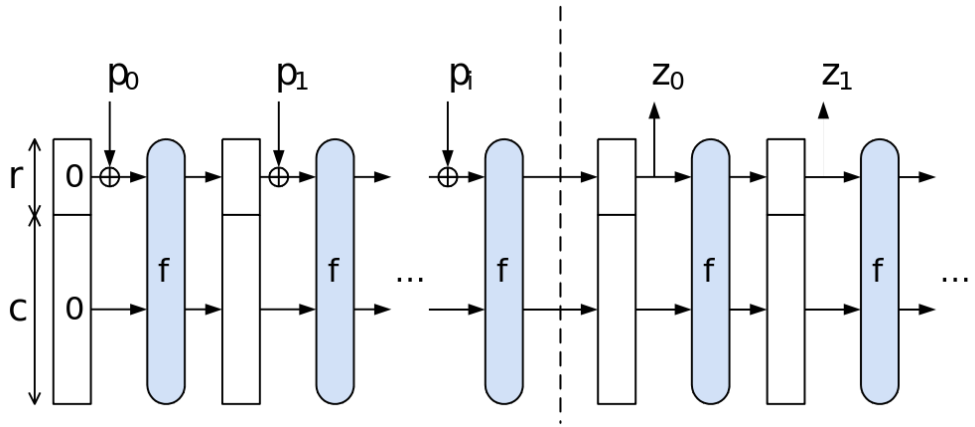


Diagram of a sponge construction from http://sponge.noekeon.org/

- Bertoni, Daemen, Peteers és Van Assche fejlesztése
- *Szivacs konstrukció* – egy rögzített hosszúságú f permutáció + padding szabály:

1. m pad-elve és felszabdalva r-bites p_i blokkokra
2. felszívás: iterált f függvény végrehajtás: p_i XOR-olva a hash állapotba adott r arányban összefésülve az előző f kimenettel
3. összenyomás: z_i output blokkok kinyerése hasonlóan, ugyanazzal az aránnyal

Alkalmazások

Mindenre is

- Jelszó kezelés (adatbázis password hash-ekből)
- Password hash verseny győztes: Argon2

Alkalmazások

Mindenre is

- Jelszó kezelés (adatbázis password hash-ekből)
- Password hash verseny győztes: Argon2
- Jelszó törés (szótár-alapú + szivárvány táblák)
- "Jó" jelszó: min 15 karakter...

Alkalmazások

Mindenre is

- Jelszó kezelés (adatbázis password hash-ekből)
- Password hash verseny győztes: Argon2
- Jelszó törés (szótár-alapú + szivárvány táblák)
- "Jó" jelszó: min 15 karakter...
- Peer-to-peer hálózatok (elosztott hash táblák aka. DHT)

Alkalmazások

Mindenre is

- Jelszó kezelés (adatbázis password hash-ekből)
- Password hash verseny győztes: Argon2
- Jelszó törés (szótár-alapú + szivárvány táblák)
- "Jó" jelszó: min 15 karakter...
- Peer-to-peer hálózatok (elosztott hash táblák aka. DHT)
- Fájlmegosztás (Merkle-fák a Bittorrent protokollban)

Alkalmazások

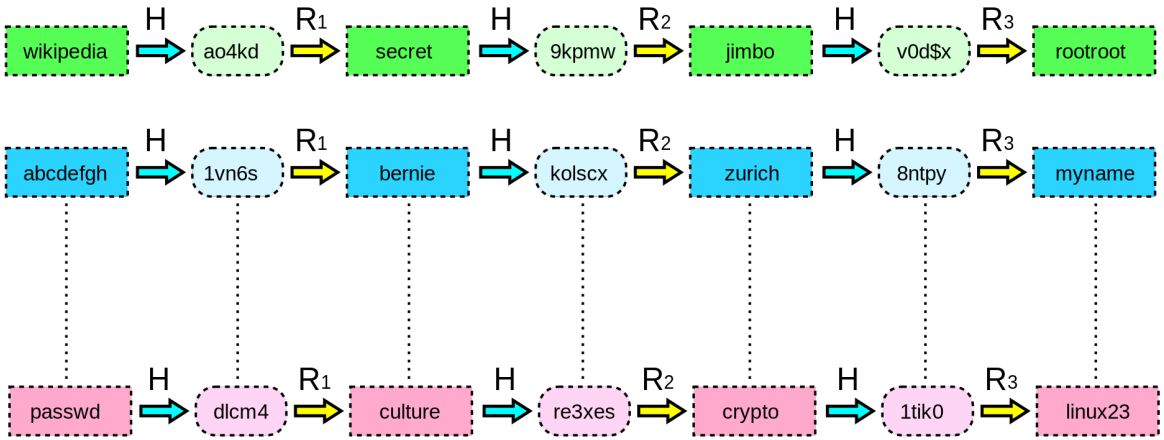
Mindenre is

- Jelszó kezelés (adatbázis password hash-ekből)
- Password hash verseny győztes: Argon2
- Jelszó törés (szótár-alapú + szivárvány táblák)
- "Jó" jelszó: min 15 karakter...
- Peer-to-peer hálózatok (elosztott hash táblák aka. DHT)
- Fájlmegosztás (Merkle-fák a Bittorrent protokollban)
- Kripto-pénzek (block-chain)

Szivárvány táblák

Őskép keresés előre számított hash-lánc táblákkal

- Cél: jelszó visszaállítás a pw hash-ek adatbázisából
- Input-output párok tárolása hash-redukció láncokhoz
- Redukció fv: hash értékből egy fix hosszú "pszeudo-őskép" számítása
- Nem invertál, csak hozzárendel egy lehetséges jelszót

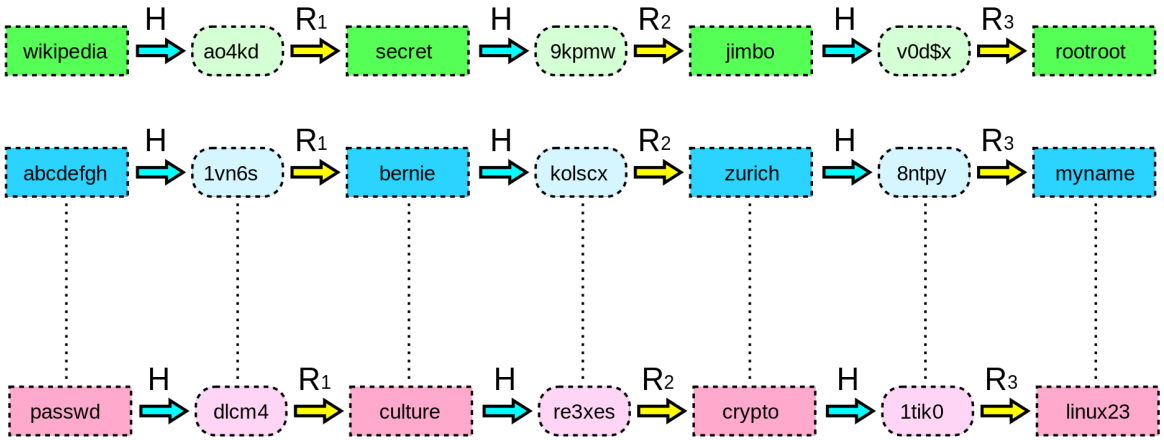


Szivárvány tábla 3 redukciós fv-el for Wikipedia created by User:Dake

Szivárvány táblák

Őskép keresés előre számított hash-lánc táblákkal

- Adott h célpont hash-értékhez redukció-hash-redukció-... lánc számítása
- Azonos output értékek keresése $\Rightarrow$ a nyílt jelszó a láncból kiolvasható
- Ellenintézkedés: kulcs-deriváló fv + "só" (extra rnd input)



Szivárvány tábla 3 redukciós fv-el for Wikipedia created by User:Dake

Ma is tanultam valamit

Összegzés

- Hash: fix rövid lenyomat tetszőleges inputból
- Ütközésmentesség
- NIST szabványosítási folyamat
- SHA-3 szivacs konstrukció